

RISK MANAGEMENT Specification



Table of Contents

Task 1: Cyber Threat Intelligence and Incident Response.....	3
a. Cyber Incident at the University of the West of Scotland (UWS) Details	3
Victim organization details	3
Details of incident	3
Date incident occurred	4
Impact on UWS.....	4
Identification of the Ransomware Group (Rhysida)	4
Data Held for Ransom	5
b. Incident Analysis.....	5
Access Vector	5
Incident Indicators	5
Known vulnerability exploited	6
Evidence collected	6
Incident duration	7
Source of the incident (IP, Port, URL).....	7
Estimated Impact of the incident	7
c. Courses of Action	8
d. Lessons Learned.....	8
Recovery actions.....	8
Containment actions.....	8
Reporting actions	8
Task 2: Automated Vulnerability Scanning and Analysis.....	9
1. How many vulnerability items did you find according to High, Medium, and low?	9
Nessus:	9
Metasploit:	16
2. What are the Common Vulnerabilities and Exposures (CVE) numbers for the vulnerabilities discovered?	17
3. Choose one of the vulnerabilities with a scoring of MEDIUM or HIGH rating scale and explain the vulnerability in your own words:	18
a. What is the vulnerability?	19
b. How could it be exploited?	19
c. How could it be fixed?	19

Task 3 Asset Register	19
Task 4 Threat Analysis and Risk Analysis Models	20
Risk Heat Map:	20
Threat Analysis Model:	22
Task 5: Risk Register	23
Task 6: Risk Control and Mitigation Actions	24
Task 7: Security Training and Awareness Program	29
Program objectives:	29
Target audience:	29
Topics to be addressed:	29
Documents:	30
Feedback and evidence of learning:	30
References	31

Table of Figures:

Figure 1: The industry and country detection count for Rhysida ransomware based on Trend SPN data from May to August 2023	6
Figure 2: Rhysida attack procedure ((Research, 2023).....	7
Figure 3: Create Scan.....	9
Figure 4: uws.ac.uk host ip discovery.....	10
Figure 5: Scan complete.....	10
Figure 6: Vulnerabilities found	11
Figure 7: Nessus Note	12
Figure 8: My Basic Network Scan / Plugin #10287	13
Figure 9: My Basic Network Scan / Plugin #11936	13
Figure 10: My Basic Network Scan / Plugin #10919	14
Figure 11: Device Type	14
Figure 12: Common Platform Enumeration (CPE)	15
Figure 13: SSL Root Certification Authority Certificate Information	15
Figure 14: Metasploit.....	17
Figure 15: CVE-2020-1472 Detail.....	18
Figure 16: This CVE is in CISA's Known Exploited Vulnerabilities Catalog.....	18
Figure 17: Weakness Enumeration	18
Figure 18: CVE (CVE, 2024)	19
Figure 19: Risk Heatmap	21
Figure 20: Threat Analysis Model	23

List of Tables:

Table 1: Asset Register Data	20
Table 2: Risk Heat Map Data.....	21
Table 3: Threat Analysis Model Data	22
Table 4: Risk Register Data	24
Table 5: Risk Control and Mitigation Actions	28

Case Study: [Scottish university UWS targeted by cyber attackers - BBC News](#)

CYBER THREAT INTELLIGENCE AND RESPONSE

Task 1: Cyber Threat Intelligence and Incident Response

a. Cyber Incident at the University of the West of Scotland (UWS) Details

The University of the West of Scotland (UWS) recently experienced a significant cybersecurity incident involving the infiltration of its digital systems by a ransomware group known as Rhysida. This incident was initially reported on 6th July, with the university's website going offline, affecting various aspects of its operations. Subsequently, Rhysida ransomware group demanded a ransom of 20 bitcoin (£450,000) for the release of sensitive and confidential data. The incident had substantial consequences, affecting staff laptops, disabling approximately half of UWS's IT systems, and impacting student submissions (News, 2023). The following are some details of the incident:

Victim organization details

There are campuses of the public University of the West of Scotland (UWS) in Paisley, Ayr, Dumfries, and Blantyre in addition to London. About 15,000 students are enrolled, with 1,300 employees. It provides a range of courses in disciplines such as business, engineering, health, social sciences, and education. The University of Paisley was established in 2007 after Bell College merged with the university. According to Times Higher Education's World University Rankings 2023 (Scotland, n.d.), it is one of the world's top 600 universities.

Details of incident

- On July 6, 2023, the institution contacted authorities to report a "ongoing cyber incident" damaging several of its digital systems.
- The university's website experienced a technical difficulty and an error message was shown.
- Rhysida, a ransomware organization, took credit for the attack and wanted 20 bitcoin (about £450,000) in exchange for the stolen data from the university.
- Staff members' financial information and social security numbers were among the documents and files from the university that were marketed by the gang. The group also threatened to sell or publish the data if the institution did not pay within seven days.

Date incident occurred

The cyber incident at the University of the West of Scotland (UWS), which transpired on 6 July 2023, unfolded as follows:

- Initial reports of the "ongoing cyber incident" at the University of the West of Scotland (UWS) were made on July 6, 2023. The incident was reported to the police on July 3, 2023.
- At the same time, there was a major outage that prevented anyone from accessing the university's website; an error message explained the cause and expressed regret for the disturbance.
- In light of a "ongoing cyber incident," UWS has admitted that its digital infrastructure has been compromised.
- Graduations during that week were still announced by the university despite the issue.
- As soon as the university became aware of the problem, it began working with the Scottish government, the National Cyber Security Centre, and Police Scotland to find a solution.

Impact on UWS

The cyber incident on 6 July 2023 had significant repercussions on the University of the West of Scotland (UWS), as elucidated by web search results:

- The university's website became inoperable and displayed an error message apologizing for the inconvenience.
- Digital systems were severely affected, including staff laptops, email services, and online learning platforms.
- The incident disrupted the regular flow of student submissions and assessments.
- The security breach resulted in the exposure of sensitive staff data, encompassing details such as bank information and national insurance numbers, to the ransomware group Rhysida.
- Rhysida demanded a ransom of 20 bitcoins, equivalent to approximately £450,000, for the return of the confidential data.
- The cyber incident tarnished the university's reputation and eroded the trust of its stakeholders.

Identification of the Ransomware Group (Rhysida)

The ransomware group responsible for the cyber incident at UWS was identified as Rhysida. Rhysida, a relatively new player in the ransomware landscape, emerged in May 2023. The group primarily targeted various industries, with a notable focus on the healthcare sector.

Data Held for Ransom

As a result of the cyber incident, a trove of data was held for ransom by the Rhysida ransomware group. The data advertised for sale included:

- Personal data belonging to university staff, notably sensitive information such as bank details and national insurance numbers.
- Internal documents pertinent to the university.
- Student submissions and assessments.

For the release of this material, Rhysida sought a large ransom of 20 bitcoins, or roughly £450,000. If the institution would not agree with their demands, they threatened to sell the data to the highest bidder. This development led to a complicated scenario that needed to be handled by UWS, law enforcement, and cybersecurity specialists in unison.

b. Incident Analysis

Access Vector

None of the accessible sources specifically address the access vector for the 2023 cyber incident at the University of the West of Scotland (UWS). The event did, however, appear to have impacted personnel data as well as some digital systems. The incident disrupted student submissions, affected staff devices, and turned off around half of the university's IT infrastructure. It's difficult to pinpoint the precise access vector without more details, however this hints that it may have involved phishing or network intrusion. An assault of this kind usually entails encrypting files on a device and requesting a ransom to unlock them. The ransomware group Rhysida took credit for the attack. Remember that the actual access vector may differ from this conjecture, which is based on the information that is now accessible.

Incident Indicators

The following are the incident indicators for the 2023 cyber incident at the University of the West of Scotland (UWS):

- **System Disruptions:** There were disturbances to several digital systems at the university¹. This included about half of the university's IT infrastructure as well as staff laptops. Submissions from students were also impacted.
- **Website Downtime:** For a while, the university's website was unavailable.
- **Data Theft:** Rhysida, a ransomware gang, took credit for the attack and promoted stolen material on their deep web domain. Internal university documents were among the personal information that belonged to the faculty, including bank account information and social security numbers.
- **Ransom Demand:** The ransomware gang demanded 20 bitcoin (£450,000) for the confidential data and threatened to sell it to the highest bidder.

A significant cyber event involving system disruption, data theft, and a ransom demand is suggested by these indicators.

Known vulnerability exploited

The materials that are now available do not specifically address the particular vulnerability that was used in the cyber incident at the University of the West of Scotland (UWS) in 2023. It is known, nevertheless, that Rhysida, a ransomware gang, took credit for the attack. Typically, ransomware attacks encrypt files and demand a payment to unlock them by taking advantage of security flaws in a system. Without more specific information, it's difficult to determine the exact vulnerability that was exploited. It's important to note that this is speculation based on available information and the actual vulnerability exploited may be different.

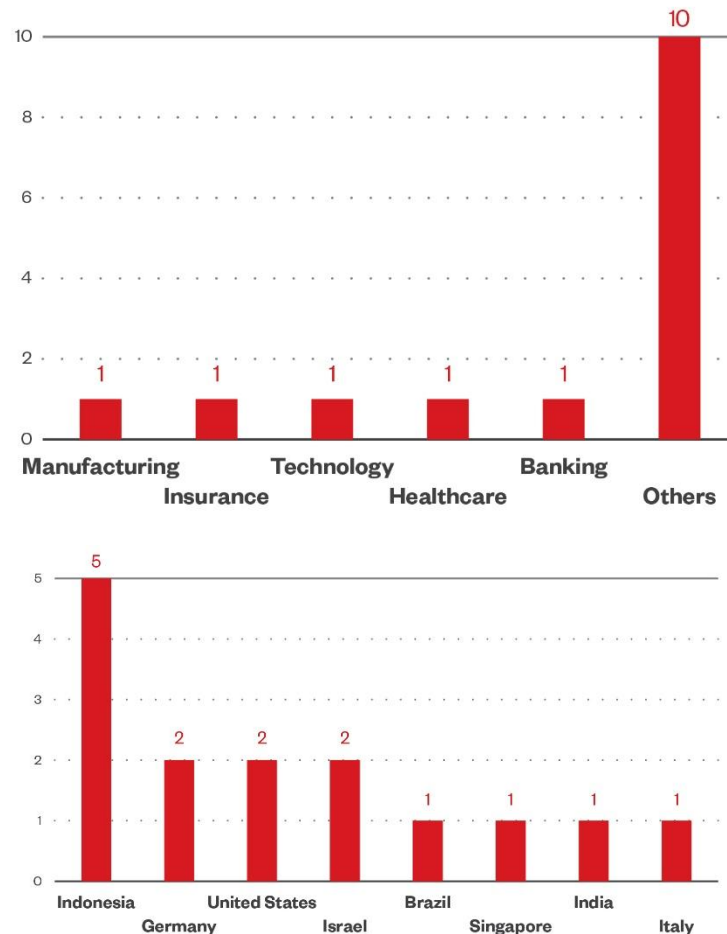


Figure 1: The industry and country detection count for Rhysida ransomware based on Trend SPN data from May to August 2023

Evidence collected

Evidence recovered from the cyber event includes data stolen by the ransomware group Rhysida and later sold at auction. The gang's deep web domain offers for sale sensitive university documents and the personal financial information of staff members, including bank account data and social security numbers. The BBC has confirmed that the group listing is real, but they were unable to independently verify the material. Memory dumps, network traffic, logs, and malware samples may have been gathered from live systems that were affected by the incident.

Incident duration

The search results don't specify how long the incident continued, but looking at when the reports were made, we may guess that it went on for at least three weeks. On July 6, the university notified authorities of the incident, and by July 28, the university stated that work had been made toward a resolution. Due to the current criminal investigation, some details are being kept under wraps. It is therefore possible that the incident began before 6 July or lasted after 28 July.

Source of the incident (IP, Port, URL)

The source of the incident is not disclosed in the web search results, but it is likely that the attackers used a remote-viewing software to access the university's systems and exploit the ZeroLogon vulnerability. The remote-viewing software may have been installed by a staff member who was tricked by a phishing email or a malicious website. The attackers may have also used a command-and-control server to communicate with the infected systems and deploy the ransomware. The IP, port, and URL of these sources are unknown at this time. This is process that provides idea that how the Ryside Attack proceeds:

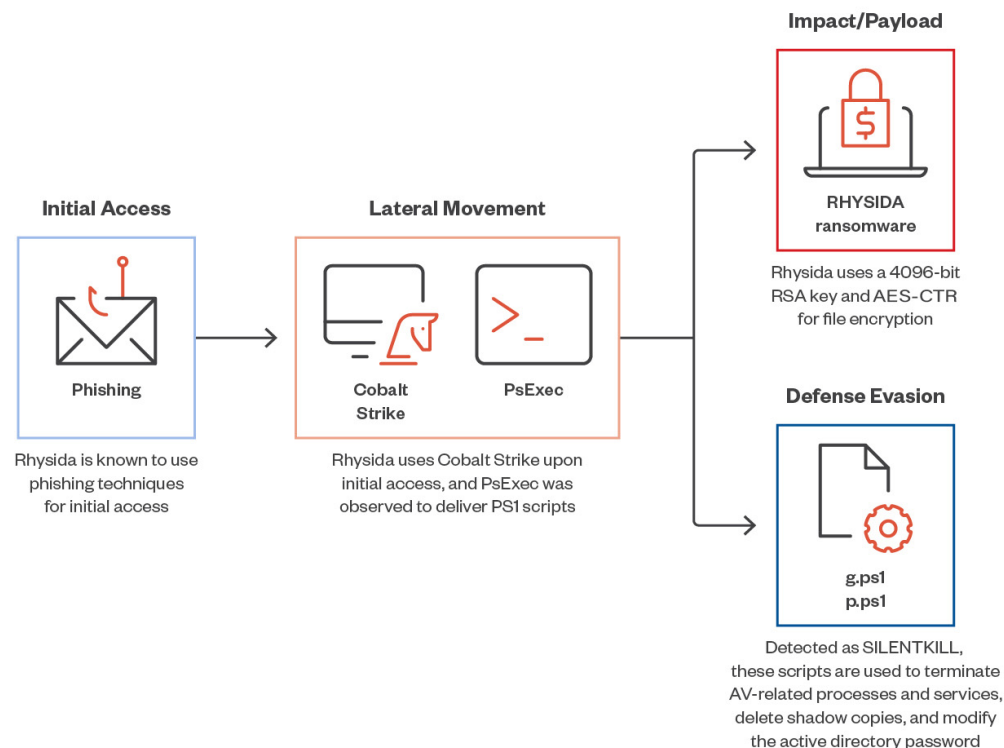


Figure 2: Rhysida attack procedure ((Research, 2023)

Estimated Impact of the incident

The occurrence could have far-reaching consequences for the university and its stakeholders, including but not limited to financial losses, reputational harm, legal liability, disruptions in operations, and psychological distress, all of which are difficult to measure. Rhysida, a ransomware group, is holding sensitive information hostage for 20 bitcoin (about £450,000). The institution could be fined or sued if it breaches contracts with partners or customers or if it is found to have violated data protection rules. The university's website was down for several days

and some of its IT systems were shut off or affected by the incident, which may have hampered its academic and administrative activities. The staff and students may have experienced anxiety, frustration, or anger due to the loss or exposure of their personal or sensitive data.

c. Courses of Action

The following actions were taken in response to the July 2023 cyber incident at the University of the West of Scotland (UWS):

- After the incident was discovered on July 6, authorities worked closely with the National Cyber Security Centre, the Scottish government, Police Scotland, and academic specialists.
- The institution, with the aid of both internal and external resources, followed a methodical procedure and worked steadily toward a solution.
- The university notified its employees and students about the breach and informed them that the attackers had access to some employee data.
- The university ensured that graduations planned for that week were not affected by the incident.
- The university restored some areas of its website that were down due to the incident.

d. Lessons Learned

The following are some potential takeaways from the July 2023 cyber attack at the University of the West of Scotland (UWS):

Recovery actions

The institution should assess its recovery objectives, priorities, and protocols to ensure they are commensurate with its business needs and level of comfort with risk. Along with evaluating the success and efficiency of its recovery initiatives—like setting up a new email service, ICT network, and devices—the institution should also look for any weaknesses or potential areas for development. Along with assessing how the incident has affected its operations, finances, reputation, and stakeholders, the institution should put policies in place to lessen any losses or damages or make up for them.

Containment actions

To ascertain whether its containment plan and decision-making procedure were suitable and prompt for the kind and gravity of the occurrence, the institution should review them. The university should also investigate the attack's origin and vector, including the remote-viewing software and the Zerologon vulnerability, and confirm that they have been completely fixed or eradicated. In order to stop or identify such assaults in the future, the university should also evaluate its security procedures and guidelines.

Reporting actions

In order to ensure compliance with the General Data Protection Regulation (GDPR) and the Data Protection Act 2018 (Acts, 2018), the university must assess its reporting requirements and procedures. The academic institution must evaluate how it handled the situation and pinpoint any shortcomings by examining how it collaborated and communicated with other parties, such as

the police, students, the Scottish government, and the Information Commissioner. Considering the current situation, the organization must consider methods to improve accountability and transparency to the public and media.

SECURITY RISK ASSESSMENT AND MANAGEMENT

Task 2: Automated Vulnerability Scanning and Analysis

1. How many vulnerability items did you find according to High, Medium, and low?

Nessus:

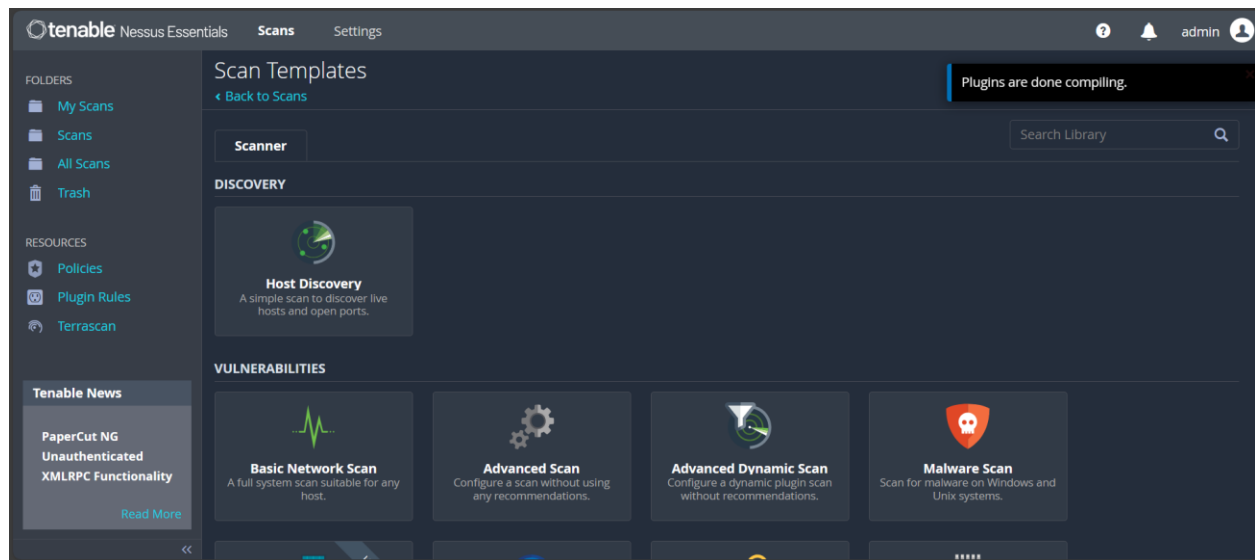


Figure 3: Create Scan

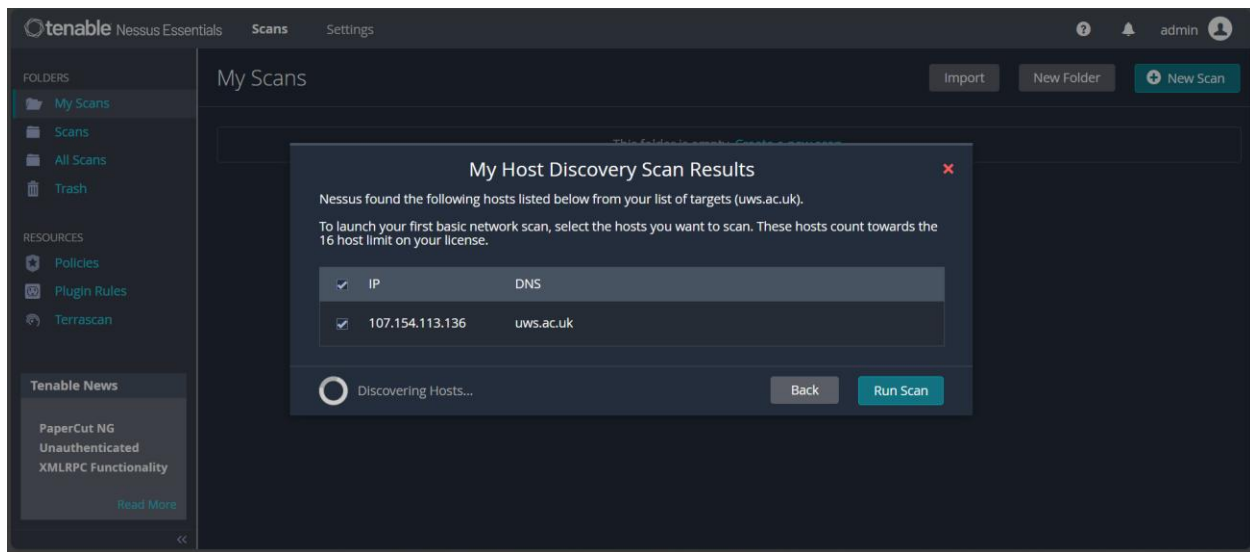


Figure 4: uws.ac.uk host ip discovery

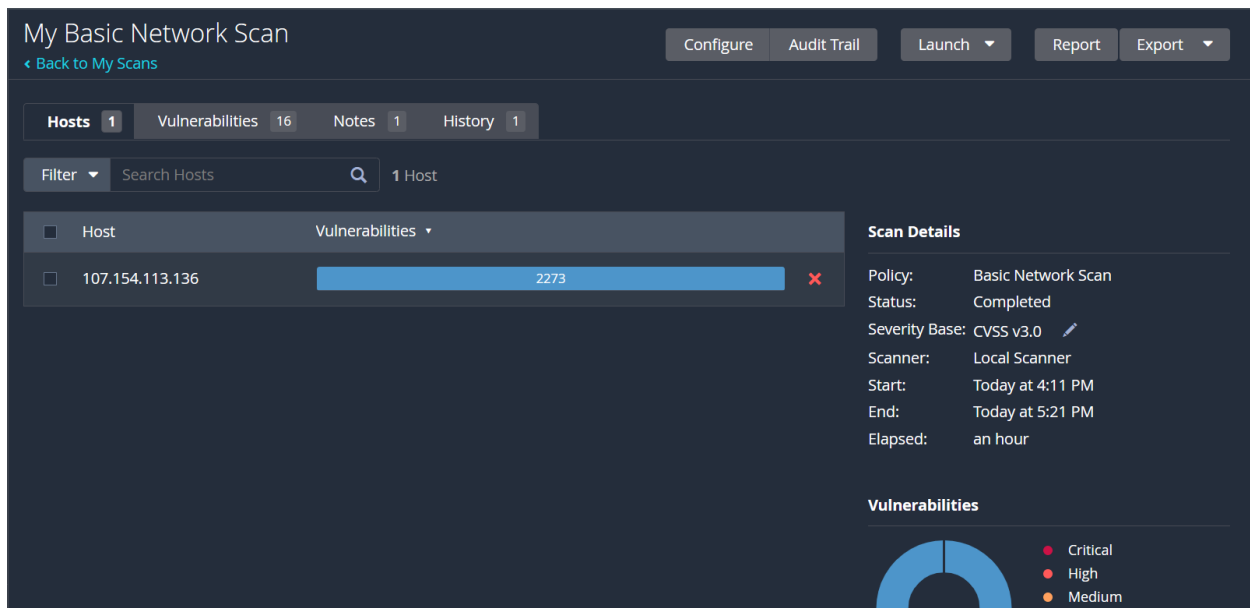


Figure 5: Scan complete

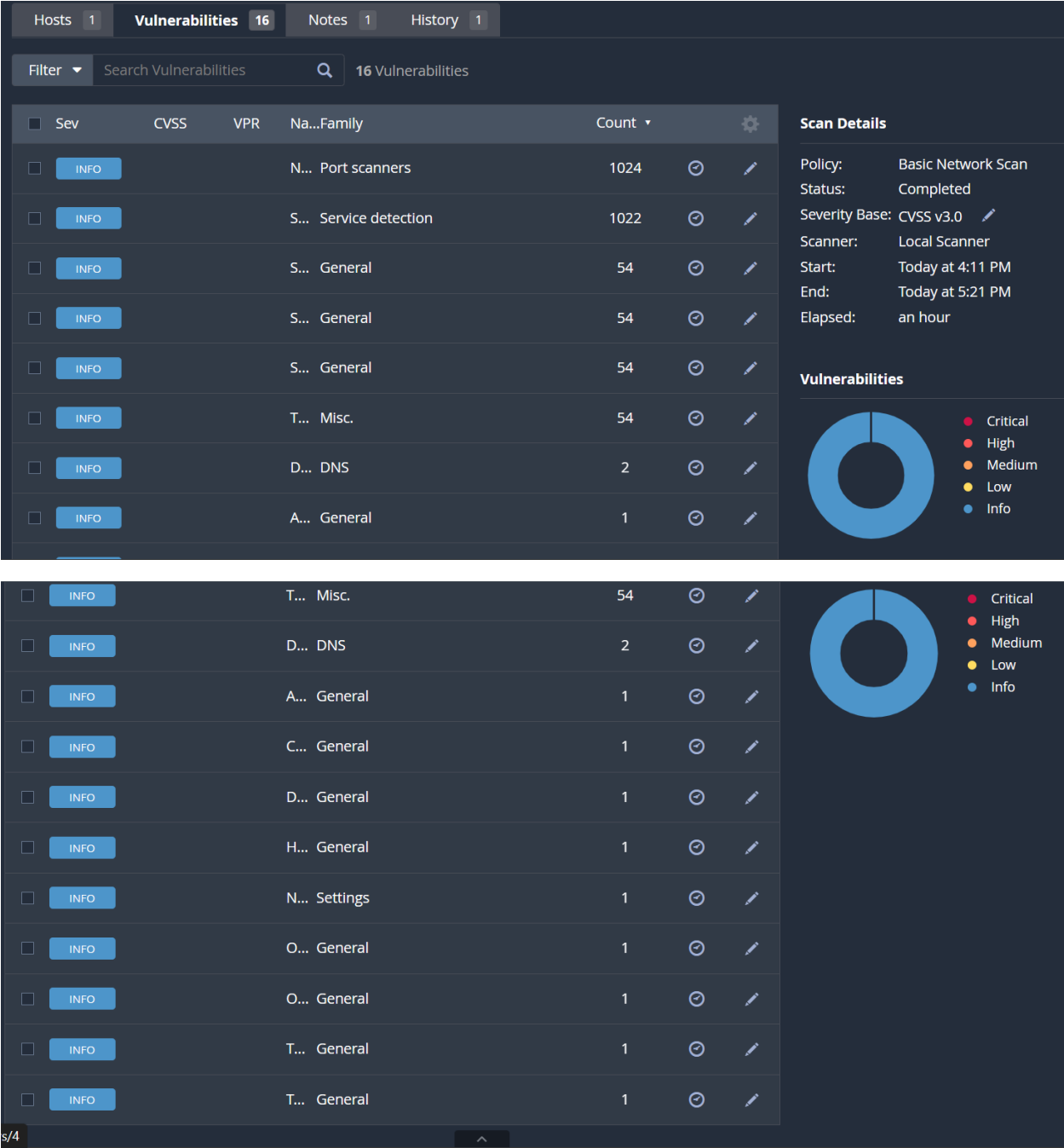


Figure 6: Vulnerabilities found

My Basic Network Scan

Configure

Audit Trail

Launch

Report

Export

[Back to My Scans](#)

Hosts 1

Vulnerabilities 16

Notes 1

History 1

Search Notes

1 Note

Scan Notes

Portscanner Max Ports Exceeded

Warning: portscanners have found more than 1024 ports open for target 107.154.113.136, and the number of reported ports has been truncated to 1024 (threshold controlled by scanner preference portscanner.max_ports). Usually this is due to intervening network equipment intercepting and responding to connection requests as a countermeasure against portscanning or other potentially malicious activity. Since this negatively impacts both scan accuracy and performance, you may want to adjust your network security configuration to disable this behavior for vulnerability scans.

Scan Details

Policy: Basic Network Scan

Status: Completed

Severity Base: CVSS v3.0

Scanner: Local Scanner

Start: Today at 4:11 PM

End: Today at 5:21 PM

Elapsed: an hour

Figure 7: Nessus Note

Output

Port 11/tcp was found to be open

To see debug logs, please visit individual host

Port	Hosts
11 / tcp	107.154.113.136

Port 21/tcp was found to be open

To see debug logs, please visit individual host

Port	Hosts
21 / tcp	107.154.113.136

RISK INFORMATION

Risk Factor: None

My Basic Network Scan / Plugin #10287

Configure
Audit Trail
Launch
Report
Export

[Back to Vulnerabilities](#)

Hosts
1
Vulnerabilities
16
Notes
1
History
1

INFO

Traceroute Information

Description

Makes a traceroute to the remote host.

Output

```

For your information, here is the traceroute from 192.168.100.106 to 107.154.113.136 :
192.168.100.106
192.168.100.1
58.65.175.240
172.31.5.21
172.31.5.210

Hop Count: 4

To see debug logs, please visit individual host

```

Port

Hosts

0 / udp

107.154.113.136

Plugin Details

Severity: Info
ID: 10287
Version: 1.70
Type: remote
Family: General
Published: November 27, 1999
Modified: June 26, 2023

Risk Information

Risk Factor: None

Figure 8: My Basic Network Scan / Plugin #10287

My Basic Network Scan / Plugin #11936

Configure
Audit Trail
Launch
Report
Export

[Back to Vulnerabilities](#)

Hosts
1
Vulnerabilities
16
Notes
1
History
1

INFO

OS Identification

Description

Using a combination of remote probes (e.g., TCP/IP, SMB, HTTP, NTP, SNMP, etc.), it is possible to guess the name of the remote operating system in use. It is also possible sometimes to guess the version of the operating system.

Output

```

Remote operating system : Linux Kernel 2.6
Confidence level : 65
Method : SinFP

The remote host is running Linux Kernel 2.6

To see debug logs, please visit individual host

```

Port

Hosts

N/A

107.154.113.136

Plugin Details

Severity: Info
ID: 11936
Version: 2.62
Type: combined
Family: General
Published: December 9, 2003
Modified: October 26, 2023

Risk Information

Risk Factor: None

Vulnerability Information

Asset Inventory: True

Figure 9: My Basic Network Scan / Plugin #11936

Output

Port 4160 was detected as being open but is now closed
Port 119 was detected as being open but is now closed
Port 2202 was detected as being open but is now closed
Port 2600 was detected as being open but is now closed
Port 8184 was detected as being open but is now closed
Port 1250 was detected as being open but is now closed
Port 9103 was detected as being open but is now closed
Port 15363 was detected as being open but is now closed
Port 2734 was detected as being open but is now closed
Port 2698 was detected as being open but is now closed
Port 2224 was detected as being open but is now closed
Port 2119 was detected as being open but is now closed
Port 3072 was detected as being open but is now closed
Port 990 was detected as being open but is now closed
Port 2582 was detected as being open but is now closed
Port 8060 was detected as being open but is now closed
Port 5000 was detected as being open but is now closed
Port 3521 was detected as being open but is now closed
Port 9201 was detected as being open but is now closed
Port 2535 was detected as being open but is now closed
Port 2867 was detected as being open but is now closed
Port 2232 was detected as being open but is now closed
Port 1364 was detected as being open but is now closed
Port 1700 was detected as being open but is now closed
Port 9205 was detected as being open but is now closed
Port 2754 was detected as being open but is now closed
Port 1978 was detected as being open but is now closed
Port 97 was detected as being open but is now closed
Port 2785 was detected as being open but is now closed
Port 285 was detected as being open but is now closed
Port 5226 was detected as being open but is now closed
Port 3572 was detected as being open but is now closed
Port 2809 was detected as being open but is now closed
Port 25006 was detected as being open but is now closed
Port 462 was detected as being open but is now closed
Port 2629 was detected as being open but is now closed
Port 1958 was detected as being open but is now closed
Port 5903 was detected as being open but is now closed
Port 5989 was detected as being open but is now closed
Port 440 was detected as being open but is now closed
Port 3042 was detected as being open but is now closed

Figure 10: My Basic Network Scan / Plugin #10919

My Basic Network Scan / Plugin #54615

[Back to Vulnerabilities](#)

ConfigureAudit TrailLaunchReportExport

Hosts1Vulnerabilities16Notes1History1

INFODevice Type

<>Plugin Details

Description

Based on the remote operating system, it is possible to determine what the remote system type is (eg: a printer, router, general-purpose computer, etc).

Output

Remote device type : general-purpose
Confidence level : 65

To see debug logs, please visit individual host

Port

Hosts

N/A107.154.113.136

Severity:Info

ID:54615

Version:1.2

Type:combined

Family:General

Published:May 23, 2011

Modified:September 9, 2022

Risk Information

Risk Factor:None

Figure 11: Device Type

My Basic Network Scan / Plugin #45590

Configure Audit Trail Launch Report Export

Hosts 1 Vulnerabilities 16 Notes 1 History 1

INFO Common Platform Enumeration (CPE)

Description
By using information obtained from a Nessus scan, this plugin reports CPE (Common Platform Enumeration) matches for various hardware and software products found on a host.

Note that if an official CPE is not available for the product, this plugin computes the best possible CPE based on the information available from the scan.

See Also
<http://cpe.mitre.org/>
<https://nvd.nist.gov/products/cpe>

Output

```
The remote operating system matched the following CPE :
cpe:/o:linux:linux_kernel -> Linux Kernel

Following application CPE matched on the remote system :
cpe:/a:ca:brightstor_arcserve_backup_agent_sql -> Computer Associates BrightStor ARCserve Backup Agent SQL
```

Plugin Details

Severity: Info
ID: 45590
Version: 1.146
Type: combined
Family: General
Published: April 21, 2010
Modified: October 16, 2023

Risk Information

Risk Factor: None

Figure 12: Common Platform Enumeration (CPE)

My Basic Network Scan / Plugin #94761

Configure Audit Trail

Hosts 1 Vulnerabilities 16 Notes 1 History 1

INFO SSL Root Certification Authority Certificate Information

Description
The remote service uses an SSL certificate chain that contains a self-signed root Certification Authority certificate at the top of the chain.

Solution
Ensure that use of this root Certification Authority certificate complies with your organization's acceptable use and security policies.

See Also
[https://docs.microsoft.com/en-us/previous-versions/windows/it-pro/windows-server-2003/cc778623\(v=ws.10\)](https://docs.microsoft.com/en-us/previous-versions/windows/it-pro/windows-server-2003/cc778623(v=ws.10))

Output

```
The following root Certification Authority certificate was found :

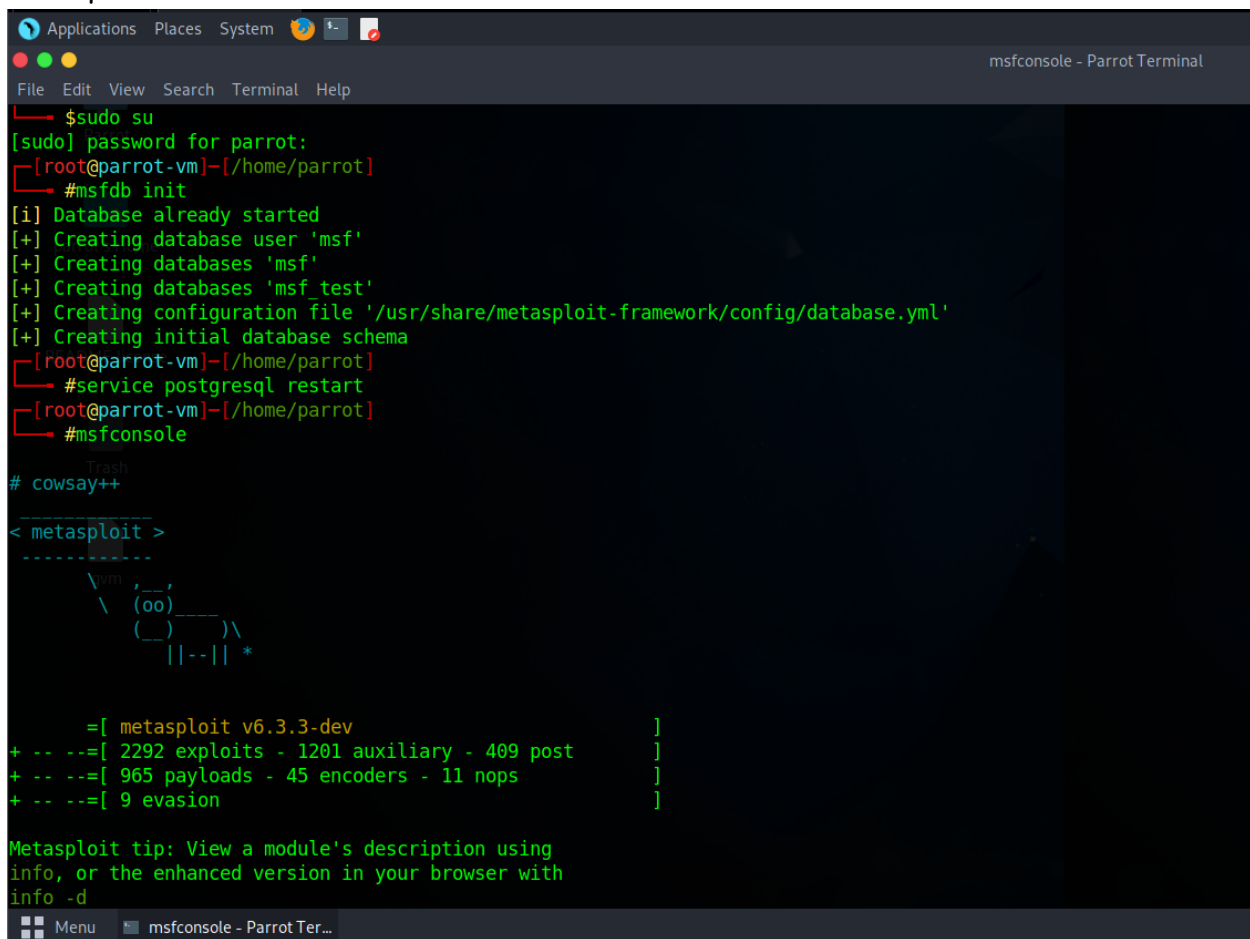
|-Subject      : OU=GlobalSign Root CA - R3/O=GlobalSign/CN=GlobalSign
|-Issuer       : OU=GlobalSign Root CA - R3/O=GlobalSign/CN=GlobalSign
|-Valid From   : Mar 18 10:00:00 2009 GMT
|-Valid To     : Mar 18 10:00:00 2029 GMT
|-Signature Algorithm : SHA-256 With RSA Encryption
```

To see debug logs, please visit individual host

Port	Hosts
25008 /tcp	107.154.113.136

Figure 13: SSL Root Certification Authority Certificate Information

Metasploit:



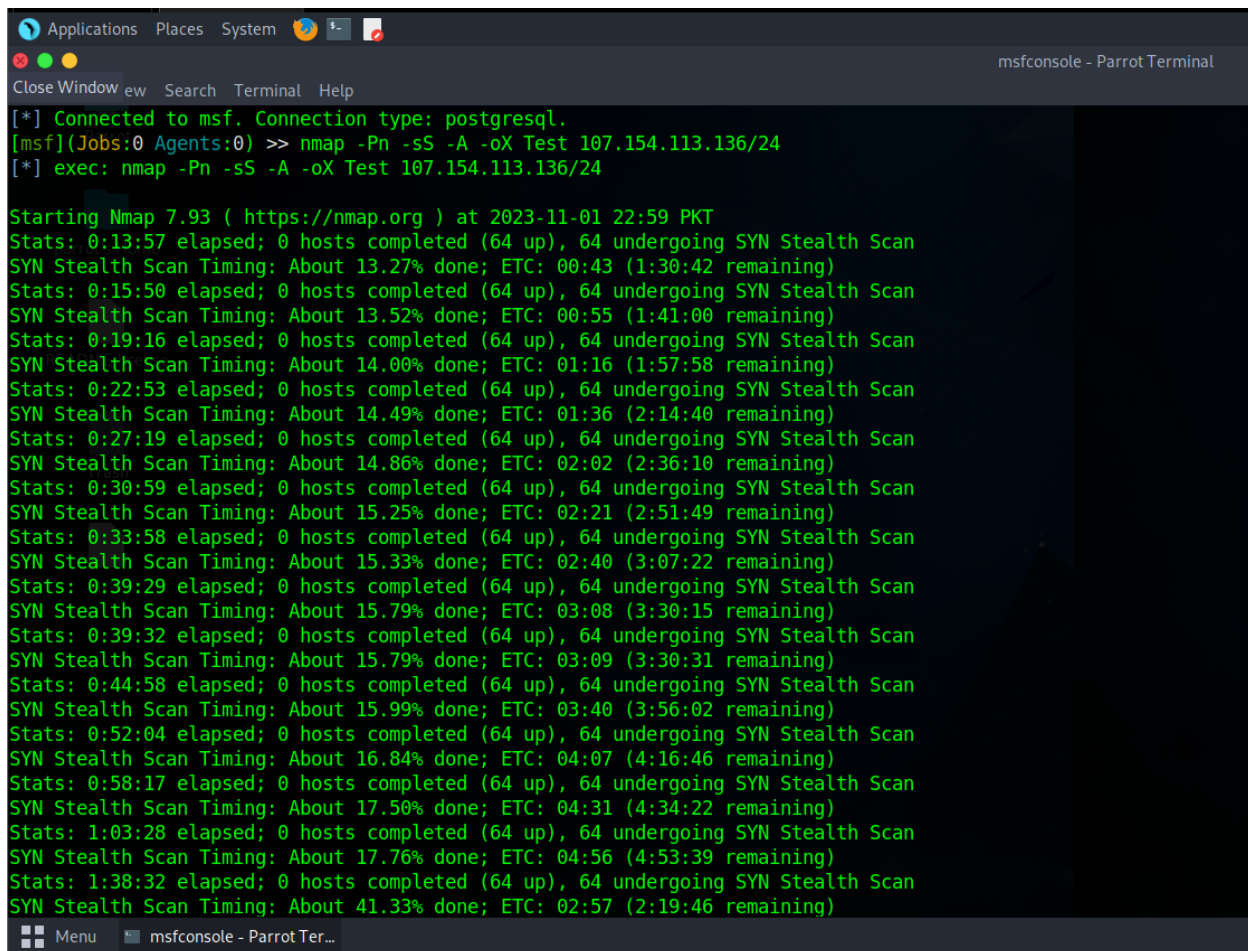
```
$sudo su
[sudo] password for parrot:
[root@parrot-vm]~/home/parrot
#msfdb init
[i] Database already started
[+] Creating database user 'msf'
[+] Creating databases 'msf'
[+] Creating databases 'msf_test'
[+] Creating configuration file '/usr/share/metasploit-framework/config/database.yml'
[+] Creating initial database schema
[root@parrot-vm]~/home/parrot
#service postgresql restart
[root@parrot-vm]~/home/parrot
#msfconsole

# cowsay++

< metasploit >
-----
      \   /_
      \  (oo)\_____)
       ( )  ( )
      ||--w (||)
      ||     ||

      =[ metasploit v6.3.3-dev                               ]
+ -- --=[ 2292 exploits - 1201 auxiliary - 409 post           ]
+ -- --=[ 965 payloads - 45 encoders - 11 nops              ]
+ -- --=[ 9 evasion                                           ]

Metasploit tip: View a module's description using
info, or the enhanced version in your browser with
info -d
```

A screenshot of a Metasploit terminal window titled 'msfconsole - Parrot Terminal'. The terminal shows a connection to 'msf' and the execution of an nmap SYN Stealth Scan on the target 107.154.113.136/24. The output displays progress statistics, including elapsed time, hosts completed, and remaining time for the scan. The scan is still in progress, with 0 hosts completed and 64 hosts undergoing the SYN Stealth Scan. The terminal window has a menu bar at the top with 'Applications', 'Places', 'System', and 'msfconsole - Parrot Terminal'. Below the menu bar is a toolbar with 'Close Window', 'ew', 'Search', 'Terminal', and 'Help'. The main area of the terminal displays the nmap output in green text on a black background.

```
[*] Connected to msf. Connection type: postgresql.
[msf](Jobs:0 Agents:0) >> nmap -Pn -sS -A -oX Test 107.154.113.136/24
[*] exec: nmap -Pn -sS -A -oX Test 107.154.113.136/24

Starting Nmap 7.93 ( https://nmap.org ) at 2023-11-01 22:59 PKT
Stats: 0:13:57 elapsed; 0 hosts completed (64 up), 64 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 13.27% done; ETC: 00:43 (1:30:42 remaining)
Stats: 0:15:50 elapsed; 0 hosts completed (64 up), 64 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 13.52% done; ETC: 00:55 (1:41:00 remaining)
Stats: 0:19:16 elapsed; 0 hosts completed (64 up), 64 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 14.00% done; ETC: 01:16 (1:57:58 remaining)
Stats: 0:22:53 elapsed; 0 hosts completed (64 up), 64 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 14.49% done; ETC: 01:36 (2:14:40 remaining)
Stats: 0:27:19 elapsed; 0 hosts completed (64 up), 64 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 14.86% done; ETC: 02:02 (2:36:10 remaining)
Stats: 0:30:59 elapsed; 0 hosts completed (64 up), 64 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 15.25% done; ETC: 02:21 (2:51:49 remaining)
Stats: 0:33:58 elapsed; 0 hosts completed (64 up), 64 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 15.33% done; ETC: 02:40 (3:07:22 remaining)
Stats: 0:39:29 elapsed; 0 hosts completed (64 up), 64 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 15.79% done; ETC: 03:08 (3:30:15 remaining)
Stats: 0:39:32 elapsed; 0 hosts completed (64 up), 64 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 15.79% done; ETC: 03:09 (3:30:31 remaining)
Stats: 0:44:58 elapsed; 0 hosts completed (64 up), 64 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 15.99% done; ETC: 03:40 (3:56:02 remaining)
Stats: 0:52:04 elapsed; 0 hosts completed (64 up), 64 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 16.84% done; ETC: 04:07 (4:16:46 remaining)
Stats: 0:58:17 elapsed; 0 hosts completed (64 up), 64 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 17.50% done; ETC: 04:31 (4:34:22 remaining)
Stats: 1:03:28 elapsed; 0 hosts completed (64 up), 64 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 17.76% done; ETC: 04:56 (4:53:39 remaining)
Stats: 1:38:32 elapsed; 0 hosts completed (64 up), 64 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 41.33% done; ETC: 02:57 (2:19:46 remaining)
```

Figure 14: Metasploit

2. What are the Common Vulnerabilities and Exposures (CVE) numbers for the vulnerabilities discovered?

The vulnerability that was exploited by the attackers was CVE-2020-1472, also known as Zerologon. This is a critical privilege escalation vulnerability that allows an attacker to compromise the Windows Netlogon Remote Protocol (MS-NRPC) and impersonate any computer on a network when trying to authenticate against the domain controller. The vulnerability was patched by Microsoft in August 2020, but some systems may not have been updated (NVD, 2020).

Severity

CVSS Version 3.x

CVSS Version 2.0

CVSS 3.x Severity and Metrics:


NIST: NVD

Base Score:

10.0 CRITICAL

Vector:
CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

NVD Analysts use publicly available information to associate vector strings and CVSS scores. We also display any CVSS information provided within the CVE List from the CNA.

Note: NVD Analysts have published a CVSS score for this CVE based on publicly available information at the time of analysis. The CNA has not provided a score within the CVE List.

Figure 15: CVE-2020-1472 Detail

Vulnerability Name	Date Added	Due Date	Required Action
Microsoft Netlogon Privilege Escalation Vulnerability	11/03/2021	09/21/2020	Apply updates per vendor instructions.

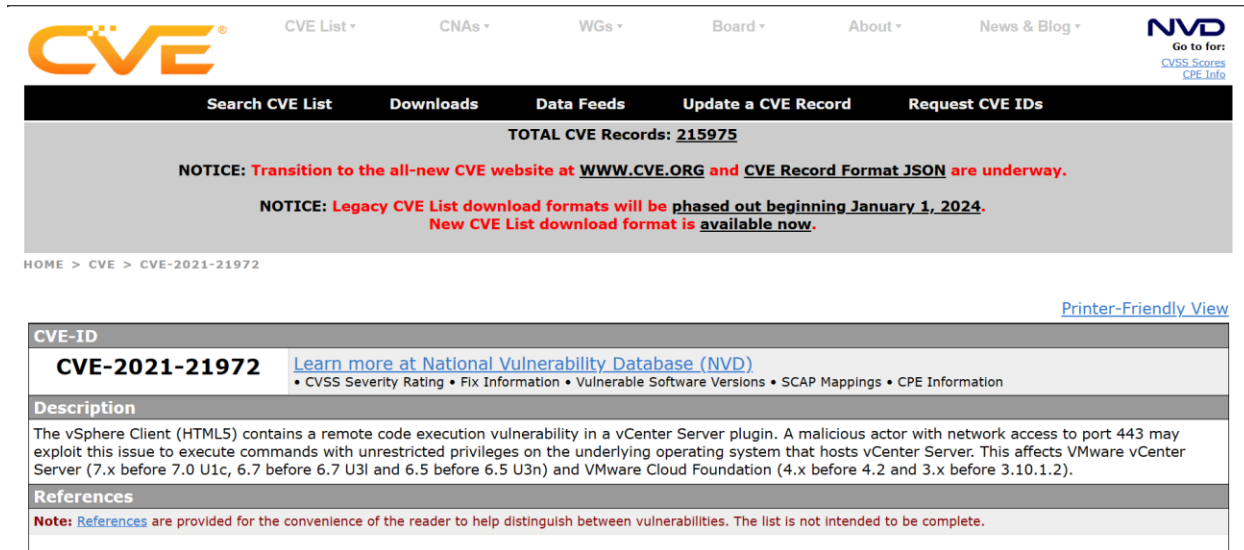
Figure 16: This CVE is in CISA's Known Exploited Vulnerabilities Catalog

CWE-ID	CWE Name	Source
CWE-330	Use of Insufficiently Random Values	 NIST

Figure 17: Weakness Enumeration

3. Choose one of the vulnerabilities with a scoring of MEDIUM or HIGH rating scale and explain the vulnerability in your own words:

CVE-2021-21972 is a remote code execution flaw in VMware vCenter Server that has been rated as MEDIUM or HIGH severity.



CVE CVE List CNAs WGs Board About News & Blog NVD Go to for: CVSS Scores CPE Info

Search CVE List Downloads Data Feeds Update a CVE Record Request CVE IDs

TOTAL CVE Records: 215975

NOTICE: Transition to the all-new CVE website at WWW.CVE.ORG and CVE Record Format JSON are underway.

NOTICE: Legacy CVE List download formats will be phased out beginning January 1, 2024. New CVE List download format is available now.

HOME > CVE > CVE-2021-21972

Printer-Friendly View

CVE-ID

CVE-2021-21972 [Learn more at National Vulnerability Database \(NVD\)](#)

• CVSS Severity Rating • Fix Information • Vulnerable Software Versions • SCAP Mappings • CPE Information

Description

The vSphere Client (HTML5) contains a remote code execution vulnerability in a vCenter Server plugin. A malicious actor with network access to port 443 may exploit this issue to execute commands with unrestricted privileges on the underlying operating system that hosts vCenter Server. This affects VMware vCenter Server (7.x before 7.0 U1c, 6.7 before 6.7 U3l and 6.5 before 6.5 U3n) and VMware Cloud Foundation (4.x before 4.2 and 3.x before 3.10.1.2).

References

Note: References are provided for the convenience of the reader to help distinguish between vulnerabilities. The list is not intended to be complete.

Figure 18: CVE (CVE, 2024)

a. What is the vulnerability?

The vulnerability is a flaw in the vSphere Client (HTML5) that allows an attacker to upload a malicious file to a vCenter Server plugin without authentication. The file can then be executed on the server with unrestricted privileges, giving the attacker full control over the server and its data.

b. How could it be exploited?

It is possible for an attacker with access to the vCenter Server's network to exploit this flaw via port 443. The attacker might build a specially structured file, such as a .jsp file for Windows computers or a public key for Linux systems, and deliver it to a susceptible endpoint of the vRealize Operations vCenter Plugin. Once the file was saved to the server, the server would run it, allowing the attacker to issue any commands they pleased.

c. How could it be fixed?

VMware has released remedies for this issue in the form of a security advisory. The updates fix the problem by requiring users to enter a username and password before using the vulnerable plugin. Alternately, the vRealize Operations vCenter Plugin could be disabled or removed from the vCenter Server to reduce the risk of exposure.

Task 3 Asset Register

Asset Name	Asset Description	Asset Type	Users	Classification	Format	Criticality	Sensitivity
Student Records	Information about students enrolled at UWS, including personal	Database	Student Services, Academic Staff, Finance Staff, External Agencies	Confidential	Electronic	High	High

	details, academic progress, fees, and scholarships.		(e.g. SLC, HESA)				
Staff Records	Information about staff employed at UWS, including personal details, payroll, contracts, performance reviews, and training.	Database	Human Resources, Payroll, Line Managers, External Agencies (e.g. HMRC, Pensions)	Confidential	Electronic	High	High
Research Data	Information generated or collected by UWS researchers, including publications, datasets, ethics approvals, and funding.	Database, Files, Documents	Researchers, Research Office, Library, External Partners (e.g. funders, collaborators)	Public, Internal, Confidential (depending on the data)	Electronic, Paper	Medium to High (depending on the data)	Low to High (depending on the data)
Course Materials	Information related to the courses offered by UWS, including syllabi, learning outcomes, assessments, and feedback.	Files, Documents, Web Pages	Academic Staff, Students, Quality Assurance, External Examiners	Public, Internal (depending on the material)	Electronic, Paper	Medium to High (depending on the material)	

Table 1: Asset Register Data

Task 4 Threat Analysis and Risk Analysis Models

Risk Heat Map:

A risk heat map is a graphical representation of the frequency and severity of certain risks, using a two-dimensional matrix. Determine the threats to your system, rank them by probability and severity, then plot them on a matrix to create a risk heat map. Each color represents a distinct level of danger. For instance, I've color-coded the hazards I've identified as minor in green, moderate in yellow, and catastrophic in red. A risk heat map is useful for pinpointing and mitigating a system's most critical concerns.

Risk ID	Risk Name	Risk Likelihood	Risk Impact	Risk Score	Risk Level	Risk Color
R1	SQL Injection Attack	Low	High	4	Medium	Yellow

R2	Ransomware Attack	Low to Medium (depending on the security posture)	High to Critical (depending on the data)	Medium to High (depending on the data)	Medium to High (depending on the data)	Yellow to Red (depending on the data)
R3	Data Breach or Leakage	Low to Medium (depending on the security posture)	High to Critical (depending on the data)	Medium to High (depending on the data)	Medium to High (depending on the data)	Yellow to Red (depending on the data)
R4	Data Loss or Corruption	Low to Medium (depending on the backup and recovery systems)	Medium to High (depending on the data)	Medium	Medium	Yellow
R5	Denial of Service Attack	Low to Medium (depending on the network security)	Medium to High (depending on the service)	Medium	Medium	Yellow
R6	Phishing or Social Engineering Attack	Medium to High (depending on the user awareness and training)	-	Medium	-	Yellow

Table 2: Risk Heat Map Data

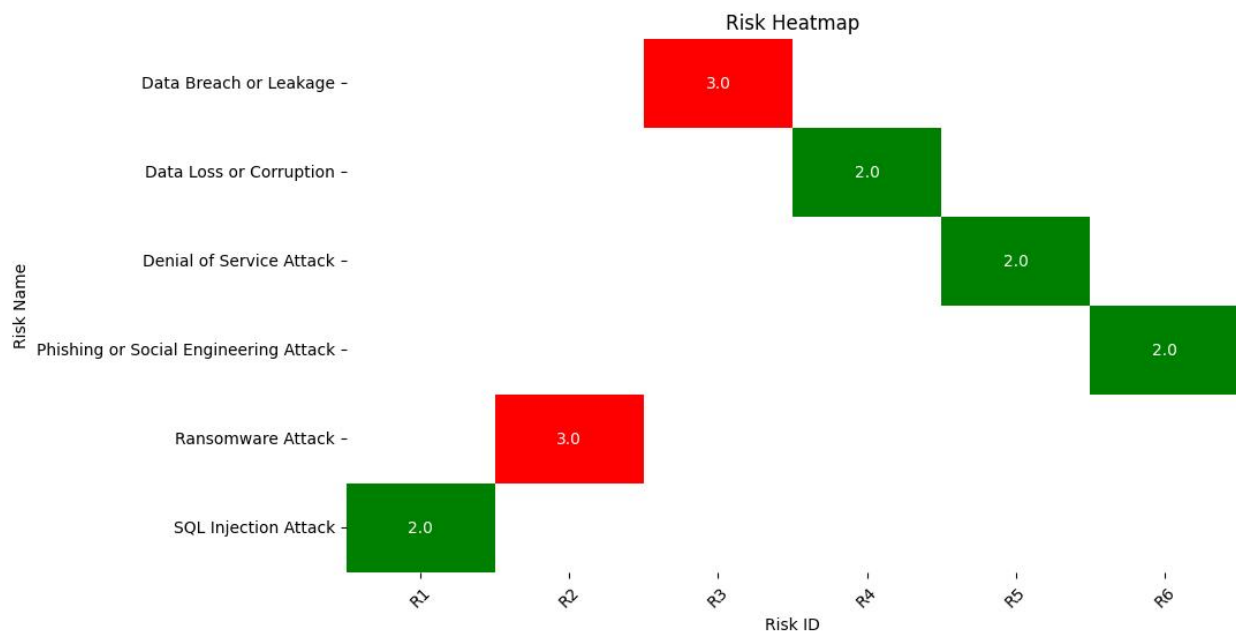


Figure 19: Risk Heatmap

I made this heatmap using python programming language on google Collab.

Threat Analysis Model:

A threat analysis model is a logical tool that helps to understand how threats may impact the system. To create a threat analysis model, we need to identify the threats that target the system, analyze their characteristics and consequences, and determine their priority. One of the methods I can use is the DREAD model, which stands for Damage, Reproducibility, Exploitability, Affected users, and Discoverability. The DREAD model assigns a score from 0 to 10 for each of these factors for each threat, and calculates the average score as the overall threat rating. A higher score indicates a higher priority threat that requires more attention and action.

Threat ID	Threat Name	Damage Potential (0-10)	Reproducibility (0-10)	Exploitability (0-10)	Affected Users (0-10)	Discoverability (0-10)	DREAD Score (0-10)
T1	SQL Injection Attack	8	8	7	9	6	7.6
T2	Ransomware Attack	9	7	6	10	5	7.4
T3	Data Breach or Leakage	10	6	5	10	4	7
T4	Data Loss or Corruption	8	5	4	9	3	5.8
T5	Denial of Service Attack	7	7	6	8	7	7
T6	Phishing or Social Engineering Attack	6	8	8	7	8	7.4

Table 3: Threat Analysis Model Data

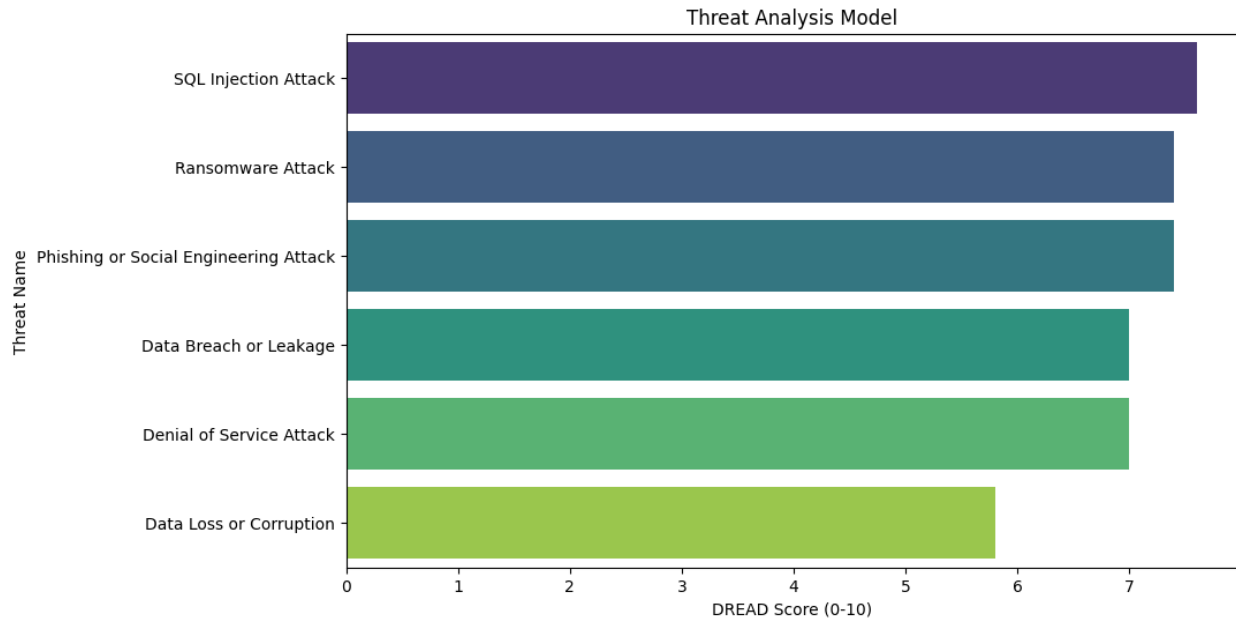


Figure 20: Threat Analysis Model

Task 5: Risk Register

Risk ID	Risk Name	Risk Category	Assets Affected by the Risk	Associated Vulnerabilities (CVE ID)	Associated Threats	Threat Priority	Risk Likelihood	Risk Impact	Risk Level
R1	SQL Injection Attack	Technical	Student Records, Staff Records, Research Data, Course Materials	CVE-2021-22986, CVE-2021-22987, CVE-2021-22988, CVE-2021-22989	Hackers, Insiders, Third Parties	High	Medium	High	High
R2	Ransomware Attack	Technical	Student Records, Staff Records, Research Data, Course Materials	CVE-2021-21972, CVE-2021-21973, CVE-2021-21974	Hackers, Cybercriminals, State Actors	High	Low to Medium (depending on the security posture)	High to Critical (depending on the data)	Medium to High (depending on the data)
R3	Data Breach or Leakage	Operational, Legal, Reputational	Student Records, Staff Records, Research Data, Course Materials	CVE-2021-34527, CVE-2020-1472, CVE-2019-19781	Hackers, Insiders, Third Parties, Media, Competitors	High to Critical (depending on the data)	Low to Medium (depending on the security posture)	High to Critical (depending on the data)	Medium to High (depending on the data)
R4	Data Loss or Corruption	Operational, Legal, Reputational	Student Records, Staff Records, Research Data, Course Materials	CVE-2020-17051, CVE-2020-17052, CVE-2020-17053	Hardware Failure, Human Error, Malicious Actors	Medium to High (depending on the data)	Low to Medium (depending on the backup)	Medium to High (depending on the data)	Medium

							and recover y systems)		
R5	Denial of Service Attack	Technical, Operational	Student Records, Staff Records, Research Data, Course Materials	CVE-2020-16898, CVE-2019-0725, CVE-2018-0886	Hackers, Cybercriminals, Competitors	Medium to High (depending on the service)	Low to Medium (depending on the network security)	Medium to High (depending on the service)	Medium
R6	Phishing or Social Engineering Attack	Human, Operational	Student Records, Staff Records, Research Data, Course Materials	-	Hackers, Cybercriminals, Third Parties	-	Medium to High (depending on the user awareness and training)	-	Medium

Table 4: Risk Register Data

Task 6: Risk Control and Mitigation Actions

Risk ID	Risk Name	Security Control Strategy	Security Control Method	Cyber Security Framework Control Category (NIST CSF)	NIST CSF Control Subcategory	Approx. Duration of Control Implementation	Approx. Cost of Control Implementation
R1	SQL Injection Attack	Prevent	Implement input validation, parameterized queries, and secure coding practices for web applications.	DE (Detect)	DE.AE-1: Establish and manage a baseline of network operations and predicted data flows for users and systems. DE.CM-1: Cybersecurity threats are tracked by network monitoring. DE.CM-4: Unwanted code has been discovered. DE.CM-7: Unauthorized users, resources, hardware, and software are tracked and reported.	3 months	\$50,000
R2	Ransomware Attack	Detect and Respond	Implement antivirus software, backup systems, and incident response plan. Educate users on how to avoid phishing emails and malicious attachments.	PR (Protect)	Data at rest is secure (PR.DS-1). PR.DS-2: Transit data is encrypted. PR.DS-5: Safeguards against leaking private information have been set up. PR.IP-12: Vulnerability management strategy is created and deployed. PR.MA-1: Organizational assets receive timely maintenance and repairs using authorized, controlled equipment. Response Please	During or after an incident, the steps outlined in the response plan are carried out. RS.CO-1: Personnel know their roles and order of operations when a response is needed. Events are reported in accordance with predetermined standards (RS.CO-2). RS.CO-3: Communication follows reaction strategies. Coordination with stakeholders occurs in	6 months

						accordance with response plans (RS.CO-4). A broader cybersecurity situational awareness is achieved by the voluntary exchange of information with external stakeholders (RS.CO-5). RS.AN-1: Detection system alerts are studied. The incident's significance is recognized (RS.AN-2). RS.AN-3: Forensics are performed. RS.AN-4: Incidents are sorted into categories in line with response strategies. The situation is under control at RS.MI-1. To reduce the severity of incidents; RS.MI-2. RS.MI-3: Unanticipated security flaws are fixed or recorded as known and acknowledged dangers. Lessons learned are included in RS.IM-1 response plans. RS.IM-2: Response strategies are updated.	
R3	Data Breach or Leakage	Prevent and Transfer	Implement encryption, access control, and data loss prevention (DLP) tools for sensitive data. Establish policies and procedures for data handling and disposal. Purchase cyber insurance to cover potential losses from data breaches.	PR (Protect)	PR.AC-1: Credentials and identities are controlled for approved hardware and users. Physical access to assets is controlled and monitored (PR.AC-2). PR.AC-3: Administration of off-site access. PR.AC-4: Permissions to resources are managed with separation of roles and least privilege in mind. PR.AC-5: Network integrity is ensured by implementing segregation of networks where necessary. PR.AC-6: Identities are validated, linked to verified credentials, and claimed in conversations. PR.AC-7: Users, devices, and other assets are authenticated (e.g., single-factor, multi-factor) commensurate with the risk of the transaction (e.g., individuals' security and privacy risks and other organizational risks). Protected Resting Data State 1 (PR.DS-1). PR.DS-2: Transport security for data. PR.DS-3: The process of moving, transferring, and selling assets is governed by established procedures. PR.DS-4: Sufficient	12 months	\$200,000

				resources to guarantee continuous service.Data leak prevention measures (PR.DS-5) are in place.PR.DS-6: Information, software, and hardware are all checked for flaws with the use of integrity checking mechanisms.PR.DS-7: The development and testing environment(s) are independent from the production environment.PR.DS-8: Hardware integrity is checked using integrity checking techniques.Processes for managing configuration changes are in place (PR.IP-3).PR.IP-4: Data is backed up, maintained, and tested regularly.PR.IP-5: The physical working environment for organizational assets is compliant with policy and legislation.PR.IP-6: Records are deleted as per established procedures.Improved security procedures constitute PR.IP-7.Protection technology effectiveness is communicated to relevant stakeholders (PR.IP-8).Plans for dealing with incidents (including Business Continuity and Incident Recovery) and recovering from them (including Disaster Recovery) are in place and being managed (PR.IP-9).PR.IP-10: Emergency procedures and backup plans are evaluated.PR.IP-11: Cybersecurity is integrated into HR procedures (such as deprovisioning and background checks).PR.IP-12: A strategy for managing vulnerabilities is created and put into action.PR.MA-1: Timely and accurate records are kept of all routine maintenance and repairs made to organizational assets using secure, authorized equipment.PR.MA-2: Organizational remote asset maintenance is permitted, documented, and carried out securely.PR.PT-1: Procedures for keeping audit and log records are established, documented, put into action, and evaluated.PR.PT-2: Discs and other removable media are secure and their use is limited.PR.PT-3: Only necessary		
--	--	--	--	--	--	--

					features are enabled in system configurations, adhering to the principle of least functionality.PR.PT-4: All control and communication networks are secure.PR.PT-5: Mechanisms (e.g., failsafe, load balancing, hot swap) are applied to satisfy resilience requirements in normal and severe scenarios.		
R4	Data Loss or Corruption	Prevent and Recover	Implement reliable data storage, backup, and recovery systems. Ensure data integrity and quality through validation and verification processes. Protect data confidentiality and ownership through encryption, access control, and legal agreements.	PR (Protect)	Protected Resting Data State 1 (PR.DS-1). PR.DS-2: Transport security for data. PR.DS-3: The process of moving, transferring, and selling assets is governed by established procedures. PR.DS-4: Sufficient resources to guarantee continuous service. PR.DS-6: Information, software, and hardware are all checked for flaws with the use of integrity checking mechanisms. PR.DS-7: The development and testing environment(s) are independent from the production environment. PR.DS-8: Hardware integrity is checked using integrity checking techniques. Processes for managing configuration changes are in place (PR.IP-3). PR.IP-4: Data is backed up, maintained, and tested regularly. PR.IP-6: Records are deleted as per established procedures. Improved security procedures constitute PR.IP-7. Recover from Catastrophe	RC.RP-1: Recovery plan is executed during or after an incident. RC.IM-1: Recovery plans incorporate lessons learned. RC.IM-2: Recovery strategies are updated. RC.CO-1: Public relations are managed. RC.CO-2: Reputation after an incident is repaired. RC.CO-3: Recovery activities are communicated to internal and external stakeholders as well as executive and management teams.	9 months
R5	Denial of Service Attack	Prevent and Respond	Implement firewalls, load balancers, network segmentation, and traffic filtering tools to protect network resources from malicious traffic. Monitor network performance and availability. Implement incident response plan to restore normal operations as	ID (Identify)	ID.AM-1: The company does an in-depth inventory of its physical assets.ID.AM-2: The company takes stock of its various software environments.ID.AM-3: An internal communication and information flow map is developed.ID.AM-4: A list of relevant outside information sources is compiled.ID.AM-5: Priorities are determined for all available resources (including hardware, devices, data, time, people, and software) in line with their kind, criticality, and economic value.ID.AM-6: Both internal and external stakeholders (suppliers, customers, partners) understand their respective responsibilities in maintaining a secure network.Organizational supply chain roles are defined and shared with stakeholders		

			soon as possible.		(ID.BE-1).ID.BE-2: The company's location in critical infrastructure and the sector it operates in are specified and shared with stakeholders.ID.BE-3: The organization's mission, goals, and activities are communicated and prioritized.Critical ID.BE-4 functions and dependencies for providing essential services are identified.All ID.BE-5s: operating states (such as under duress/attack, during recovery, and regular operations) have resilience criteria developed to sustain delivery of key services.ID.GV-1: A policy for protecting sensitive company data is put in place.ID.GV-2: Internal and external partners work together to coordinate and harmonize information security roles and responsibilities.ID.GV-3: Cybersecurity law and regulation, including obligations to protect individual privacy and civil liberties, are known and managed.ID.GV-4: Governance and risk management methods handle cybersecurity concerns.ID.RA-1: We found and recorded the weak points in the asset.ID.RA-2: Intelligence on cyber threats is gathered through various forums and other channels for the exchange of data.ID.RA-3: External and internal threats are recognized and recorded.ID.RA-4: Likelihoods and potential effects on the company are determined.ID.RA-5: Risk is evaluated in terms of potential dangers, susceptibilities, probabilities, and consequences.ID.RA-6 Prioritization of risk responses is established.ID.RM-1: Stakeholders establish, oversee, and approve risk management procedures.ID.RM-2: The organization's level of comfort with risk is defined and communicated.Organizational ID.RM-3		
--	--	--	-------------------	--	--	--	--

Table 5: Risk Control and Mitigation Actions

SECURITY TRAINING AND AWARENESS PROGRAM

Task 7: Security Training and Awareness Program

Given the foregoing information and assault, the following security training and awareness program for the organization may be appropriate:

Program objectives:

The program aims to achieve the following objectives:

- To comply with the national and local policies for cybersecurity training and awareness, such as the NIST Cybersecurity Framework (CSF) ¹, the DOD Instruction 3305.13 ², and the New York State Cybersecurity Training ³.
- to provide knowledge on best practices for managing and safeguarding IT resources, organizational security policies, and workers' security obligations.
- To raise employees' awareness of the current and emerging cyber threats, such as ransomware, phishing, data breaches, denial of service, and social engineering.
- To improve employees' security skills and behaviors, such as password management, email security, data protection, incident response, and cyber hygiene.
- To measure the effectiveness of the program and identify areas for improvement (Tan Soon Chew, 2023).

Target audience:

Everyone in the company is eligible to participate in the program, no matter their position or where they work. System administrators, researchers, managers, and regular users all have varied permissions, security risks, and training requirements, all of which are taken into account by the program.

Topics to be addressed:

Topics addressed in the show include:

- **Security basics:** Cybersecurity ideas and principles such as privacy, availability, risk management, and many layers of protection are discussed. Also detailed are the company's accepted-use and data-classification rules, as well as their access-control and incident-reporting protocols.
- **Security threats:** This section provides an overview of the most frequent forms and origins of cyberattacks, including cryptomining, phishing, data breaches, DOS, and social engineering. It also gives case studies of actual incidents that had an impact on businesses and industries similar to those covered.
- **Security practices:** Best practices for password management, email encryption, data protection, incident response, and general cyber hygiene are all covered here. It also

includes suggestions and ideas on how to avoid or reduce typical security risks and vulnerabilities.

- **Techniques for delivering the awareness materials:** The initiative distributes the educational materials to the staff in a number of ways, including:
- **Video-based training:** In this method, concise and interesting movies are used to convey the major ideas and takeaways of each subject. The videos can be accessed through a website or a learning management system (LMS). In order to ensure that the employees are learning from and retaining the material presented in the films, they are supplemented by quizzes or assessments.
- **Interactive training:** This method employs simulated, real-world events or challenges to test an individual's security knowledge and prowess through the use of interactive modules or games. A web portal or learning management system (LMS) provides online access to the interactive courses or games. In order to further cement the learning outcomes and offer improvement recommendations, the interactive modules or games are followed by feedback or debriefing.
- **Phishing simulation:** Employees' abilities to spot and thwart phishing emails and other efforts to steal sensitive information are tested using this method. Once in a while, a fake phishing assault will be staged using an external service or bot. Staff members are coached through a simulated training session on how to spot and report phishing attempts, and then given constructive criticism and possible corrective actions.

Documents:

To aid in its implementation and evaluation, the program generates the following materials:

- **Program materials:** A variety of tools such as scripts, slides, videos, interactive modules, games, quizzes, assessments, feedback forms, certifications, and more are utilized to spread awareness amongst staff members. The program materials are created to be accessible, interesting, and useful to the intended audience. Each topic's learning aims and objectives have been incorporated into the design of the corresponding course materials.
- **Program evaluation:** The evaluation results are summarized in this report, which includes data on the number of persons who participated in the program, the percentage who completed it, their level of satisfaction with the program, the amount they learned, the ways in which their behavior changed, and the amount of money that was saved. Both the program's strengths and weaknesses, as well as any areas for improvement, are highlighted in this analysis. The review lays forth objectives and makes recommendations to enhance the effectiveness and utility of the program.

Feedback and evidence of learning:

Employees' opinions and proof of learning are gathered in a number of ways, including:

- **Quizzes and assessments:** Before and after the training, employees' understanding of each topic is evaluated using these approaches. The tests and other evaluations are made to

correspond well with the stated goals and outcomes of the course. The quizzes and assessments are also assessed and recorded automatically by the LMS or the online site.

- **Feedback forms:** The purpose of these techniques is to elicit the staff's feedback on the program's efficacy and efficiency. The forms are intended to be brief, anonymous, and completely optional for the staff. The LMS or online portal also compiles and reports data from the feedback forms.
- **Certificates:** These strategies are used to recognize and reward the employees' completion and performance of the program. The certificates are made to look nice and be easily verified by the employees. It is the LMS or the web portal that issues and distributes the certificates.
- **Surveys and interviews:** After the program has been implemented, the employees' satisfaction, attitudes, and actions with regards to cybersecurity are measured using these techniques. The interviews and questionnaires are meant to be uniformly thorough, representative, and fair to all employees. A third-party evaluator or service provider also administers and examines the questionnaires and interviews.

References

- Acts, U. P. G., 2018. *Data Protection Act 2018 c.12*. [Online]
Available at: <https://www.legislation.gov.uk/ukpga/2018/12/contents/enacted>
- Content, c. C., 2023. *Rhysida Ransomware Revealed*. [Online]
Available at: <https://www.cyborgsecurity.com/threats/emerging-threats/rhysida-ransomware-revealed/>
- CVE, 2024. *CVE-2021-21972*. [Online]
Available at: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2021-21972>
- News, B. A. C. -. B., 2023. *Scottish university UWS targeted by cyber attackers*. [Online]
Available at: <https://www.bbc.com/news/uk-scotland-glasgow-west-66327336>
- NVD, N. V. D.-., 2020. *CVE-2020-1472 Detail*. [Online]
Available at: <https://nvd.nist.gov/vuln/detail/CVE-2020-1472>
- Research, T. M., 2023. *An Overview of the New Rhysida Ransomware Targeting the Healthcare Sector*. [Online]
Available at: https://www.trendmicro.com/en_us/research/23/h/an-overview-of-the-new-rhysida-ransomware.html
- Scotland, U. o. t. W. o., n.d. [Online]
Available at: <https://www.uws.ac.uk/>
- Tan Soon Chew, C. C. C. C. C. P., 2023. *Considerations for Developing Cybersecurity Awareness Training*. [Online]

Available at: <https://www.isaca.org/resources/isaca-journal/issues/2023/volume-2/considerations-for-developing-cybersecurity-awareness-training>

Team, T. R., 2023. *Rhysida Ransomware Technical Analysis*. [Online]

Available at: <https://decoded.avast.io/threatresearch/rhysida-ransomware-technical-analysis/>